FINZONE - UNIX / LINUX SUNUCU GÜVENLİK DENETİM RAPORU

Denetlenen Kurum: Finzone

Sistem: db-prod-01 (Ubuntu 22.04.4 LTS, Kernel 5.15.0-113-generic, x86-64)

Kanıt Tarihi: 18 Ağustos 2025

Referans: ISO/IEC 27001:2013 Ek A, COBIT 2019

Denetçi: Necdet Emre Bayraktar (Bilgi Sistemleri Denetçisi Adayı)

1. Yönetici Özeti

Bu rapor, Finzone'un üretim veritabanı sunucusu db-prod-01 üzerinde gerçekleştirilen Unix / Linux güvenlik denetiminin bulgularını içermektedir. Denetimin amacı Unix sistemlerinde ISO/IEC 27001 uyumluluğunu değerlendirmek, güvenlik açıklarını tespit etmek ve politika, prosedür ve teknik kontrolleri doğrulamaktır. İnceleme 7 kontrol alanında, sunucu üzerinde çalıştırılan komutların çıktıları kanıt olarak kullanılarak yapılmıştır.

SSH yapılandırması (root girişi kapalı, yalnızca anahtar tabanlı giriş), eski servislerin (Telnet, FTP) kapatılması, NTP senkronizasyonu ve logların merkezi sunucuya aktarılması gibi alanlarda kontrollerin uygun olduğu görülmüştür. Ancak sistemde HR listesinde bulunmayan bir kullanıcı hesabının (ops) aktif olduğu, OpenSSH ve OpenSSL gibi kritik paketlerin güncel olmadığı, ops hesabına root yetkisiyle tanımlanan sudo komutlarının (NOPASSWD dahil) root shell elde etmeye imkan verdiği ve /var/log/app/tmp dizininin herkes tarafından yazılabilir olduğu tespit edilmiştir.

Toplam 5 bulgu ve 2 gözlem tespit edilmiştir: 3 High, 2 Medium. Tekil eksikliklerden çok, kullanıcı yaşam döngüsü ve yama yönetimi süreçlerinin düzgün işlemediği görülmektedir.

2. Denetim Kapsamı ve Yapılan Testler

İnceleme aşağıdaki 7 başlık altında yapılmış, her başlık ISO/IEC 27001 ve COBIT 2019 kontrolleriyle eşleştirilmiştir:

Kontrol Alanı	Kullanılan Komut / Kanıt	Referans
1. Politika ve Prosedür	hostnamectl, find /etc /opt /srv (policy, procedure, standards)	ISO A.5.1, A.6.1.1; COBIT EDM01, APO01, APO07
2. Kullanıcı Envanteri	getent passwd, comm ile /etc/ passwd ve hr_users.csv karşılaştırması	ISO A.9.2.1, A.9.2.6; COBIT DSS05.04
3. SSH Konfigürasyonu	sshd -T, /var/log/auth.log (Failed password, Invalid user)	ISO A.9.4.2, A.13.1.1
4. Güncel Olmayan Paketler	apt list --upgradable, yum check-update	ISO A.12.6.1

Kontrol Alanı	Kullanılan Komut / Kanıt	Referans
5. Yetki Yönetimi	visudo -c, sudo -l -U ops	ISO A.9.2.3, A.9.4.4
6. Servisler / Daemons	systemctl list-unit-files, find / -perm -0002 (dünya yazılabilir dizinler)	ISO A.13.1.1, A.9.4.1
7. Zaman ve Loglama	timedatectl, journalctl --disk-usage, rsyslog yapılandırması	ISO A.12.4.1, A.12.4.4

3. Kontrol Alanlarına Göre Değerlendirme

Kontrol Alanı	Sonuç	Özet
Politika ve Prosedür	Kısmen	/etc/security/policy, /opt/itsec/unix_standards ve /srv/runbook/unix_procedures.md mevcut; onay, güncellik ve personele duyurulma kanıtı sunulmadı (Bulgu 5).
Kullanıcı Envanteri	Uygun Değil	ops hesabı HR listesinde yok; carol HR'de var, sistemde yok (Bulgu 1).
SSH Konfigürasyonu	Uygun	permitrootlogin no, passwordauthentication no, pubkeyauthentication yes. Loglarda başarısız denemeler var (Gözlem 1).
Güncel Olmayan Paketler	Uygun Değil	openssh-server ve openssl için bekleyen güvenlik güncellemeleri (Bulgu 2).
Yetki Yönetimi	Uygun Değil	sudoers dosyaları hatasız; ancak ops için tanımlı journalctl yetkisi root shell'e açılabiliyor (Bulgu 3).
Servisler / Daemons	Kısmen	telnet ve ftp kapalı; /var/log/app/tmp dünya yazılabilir (Bulgu 4).
Zaman ve Loglama	Kısmen	NTP aktif ve senkronize; loglar 10.10.9.20:6514 adresine aktarılıyor; journal 512 MB. Log bütünlüğü ve alarm mekanizması için kanıt sunulmadı (Gözlem 2).

4. Tespit Edilen Bulgular

Bulgu 1 - Kullanıcı Envanteri ile HR Listesi Uyuşmazlığı

getent passwd çıktısında alice (1001), bob (1002) ve ops (1010) kullanıcıları bulunmaktadır. /etc/passwd ile HR personel listesi (hr_users.csv) karşılaştırıldığında ops hesabının sistemde olduğu ancak HR listesinde bulunmadığı, carol'ın ise HR listesinde olduğu halde sistemde hesabı olmadığı görülmüştür. ops hesabının sahibi ve amacı kayıt altında değildir; servis hesabı olarak tanımlandığına dair kanıt sunulmamıştır.

- **Risk Seviyesi:** High

- **Root Cause Analysis (RCA):** İşe giriş, görev değişikliği ve işten çıkış süreçlerinin sistem hesaplarıyla eşleştirilmemesi; hesap açma / kapatma işlemlerinin HR kayıtlarından bağımsız yürütülmesi. Hesabın sahibi ayrılmış bir personelse, sorun tek bir hesaptan çok ayrılan personel hesaplarının sistemden çıkarılmamasıdır.
- **Öneri:** ops hesabının sahibi belirlenmeli; servis hesabıysa sorumlusuyla birlikte envantere kaydedilmeli ve interaktif girişi kapatılmalı, sahipsizse devre dışı bırakılmalıdır. Kullanıcı listesi en az üç ayda bir HR listesiyle karşılaştırılmalı, yazılı bir offboarding prosedürü uygulanmalıdır.

Bulgu 2 - Kritik Paketlerde Bekleyen Güvenlik Güncellemeleri

apt list --upgradable çıktısında openssh-server (1:8.9p1-3ubuntu0.8 sürümünden 0.10'a) ve openssl (3.0.2-0ubuntu1.15 sürümünden 1.17'ye) paketlerinin güncellenmeyi beklediği görülmüştür. Kanıtlar arasında yer alan yum check-update çıktısında da openssl (1:1.1.1k-12.el8_9) ve openssh (8.0p1-16.el8) paketleri için bekleyen güncellemeler bulunmaktadır. Bu çıktı RHEL 8 tabanlı bir sisteme aittir ve db-prod-01 (Ubuntu) üzerinden alınmış olamaz; hangi sunucuya ait olduğu kanıtta belirtilmemiştir. Bu durum sorunun tek bir sunucuyla sınırlı olmadığını, ayrıca sunucu envanterinin netleştirilmesi gerektiğini göstermektedir.

- **Risk Seviyesi:** High
- **Root Cause Analysis (RCA):** Kurumda düzenli işleyen bir yama yönetimi süreci, otomatik güncelleme mekanizması ve CVE takibi bulunmaması.
- **Öneri:** Bekleyen güncellemeler test edilerek uygulanmalıdır. Yalnızca bu paketlerin güncellenmesi yeterli değildir; tüm Unix sunucularını kapsayan, kritik güvenlik yamaları için süre hedefi olan bir yama yönetimi süreci ve CVE takibi oluşturulmalıdır.

Bulgu 3 - Sudo Yetkileri ile Root Yetkisine Yükselme Riski

sudo -l -U ops çıktısına göre ops kullanıcısı /usr/bin/systemctl restart nginx komutunu parola sorulmadan (NOPASSWD) ve /usr/bin/journalctl -u nginx komutunu root yetkisiyle çalıştırabilmektedir. /etc/sudoers ve /etc/sudoers.d/90-ops dosyaları sözdizimi açısından hatasızdır ve yetkiler ilk bakışta belirli komutlarla sınırlandırılmış görünmektedir. Ancak journalctl çıktıyı varsayılan olarak bir sayfalayıcı (less) ile gösterir ve root olarak açılan bu sayfalayıcıdan komut çalıştırılarak (ör. !sh) root shell elde edilebilir. Yani kısıtlı görünen bu yetki, pratikte ops hesabına tam root yetkisi vermektedir. Bu yetkinin HR listesinde bulunmayan bir hesaba verilmiş olması ve onay kaydının olmaması riski artırmaktadır.

- **Risk Seviyesi:** High
- **Root Cause Analysis (RCA):** Ayrıcalıklı yetkilerin talep ve onay süreci olmadan tanımlanması ve periyodik olarak gözden geçirilmemesi.
- **Öneri:** ops hesabının bu yetkilere gerçekten ihtiyacı olup olmadığı doğrulanmalıdır. Log okuma ihtiyacı sudo yerine hesabın systemd-journal / adm grubuna eklenmesiyle karşılanmalı veya komut --no-pager ile sınırlandırılmalıdır. NOPASSWD kullanımı yalnızca gerekçesi yazılı olan servis işlemleriyle sınırlandırılmalı ve tüm sudo yetkileri periyodik olarak gözden geçirilip kayıt altına alınmalıdır.

Bulgu 4 - Dünya Yazılabilir Uygulama Dizini

Telnet ve FTP servislerinin devre dışı olduğu, sshd ve rsyslog servislerinin aktif olduğu görülmüştür. Ancak find / -xdev -type d -perm -0002 çıktısında /tmp ve /var/tmp dışında /var/log/app/tmp dizininin de herkes tarafından yazılabilir olduğu tespit edilmiştir.

- **Risk Seviyesi:** Medium
- **Root Cause Analysis (RCA):** Uygulama dizinlerinin kurulumda geniş izinlerle oluşturulması ve dosya izinlerinin düzenli olarak denetlenmemesi.
- **Öneri:** /var/log/app/tmp dizininin izinleri yalnızca uygulama kullanıcısına yazma yetkisi verecek şekilde düzeltilmeli; zorunluysa en azından sticky bit (chmod 1777) uygulanmalıdır. Dünya yazılabilir dosya ve dizinler dosya bütünlüğü izleme (FIM) ile takip edilmelidir.

Bulgu 5 - Politika ve Prosedürlerin Onay ve Güncellik Kanıtı

Sunucuda /etc/security/policy, /opt/itsec/unix_standards ve /srv/runbook/unix_procedures.md dosya ve dizinleri bulunmuştur. Bu, Unix sistemleri için bir yönetişim sürecinin varlığına işaret etmektedir. Ancak dokümanların onaylandığına, en son ne zaman gözden geçirildiğine ve ilgili personele duyurulduğuna dair kanıt sunulmamıştır. Yukarıdaki bulgular, kullanıcı yönetimi ve yama süreçlerinin bu dokümanlara göre işletilmediğini göstermektedir.

- **Risk Seviyesi:** Medium
- **Root Cause Analysis (RCA):** Dokümantasyonun yazılı olarak bulunmasına rağmen sahiplik, onay ve gözden geçirme döngüsünün tanımlanmaması; süreçlerin kişilere bağımlı kalması.
- **Öneri:** Unix sistem yönetimi, kullanıcı yönetimi ve yama yönetimi prosedürleri için sahip, onay tarihi ve yıllık gözden geçirme tarihi belirlenmeli; dokümanlar ilgili personele erişilebilir olmalı ve uygulamaya yansıdığı periyodik olarak kontrol edilmelidir.

Gözlem 1 - SSH Brute Force Denemeleri

SSH yapılandırması iyi uygulamalara uygundur: root ile girişe izin verilmemekte, parola ile giriş kapalıdır ve yalnızca public key ile erişim sağlanmaktadır. auth.log kayıtlarında 18 Ağustos tarihinde 203.0.113.5 adresinden var olmayan "admin" kullanıcısıyla ve 203.0.113.9 adresinden root ile başarısız giriş denemeleri görülmüştür. Mevcut yapılandırma bu denemelerin başarılı olmasını engellemektedir. Yine de tekrarlayan denemeleri engellemek için fail2ban veya benzeri bir mekanizma ve SIEM üzerinde alarm kuralı tanımlanması önerilir.

Gözlem 2 - Log Bütünlüğü ve Alarm Mekanizması

Sistem saatinin NTP ile senkronize olduğu (NTP service: active, System clock synchronized: yes) ve tüm logların rsyslog ile 10.10.9.20:6514 adresindeki merkezi sunucuya TCP üzerinden aktarıldığı görülmüştür. Bu, adli süreçlerde zaman damgalarının güvenilir olması açısından olumludur. Ancak aktarımın TLS ile şifrelendiğine, merkezi sunucuda logların değiştirilemez şekilde saklandığına ve kritik olaylar için alarm kuralı tanımlandığına dair kanıt sunulmamıştır. Bu konuların merkezi log sunucusu tarafında ayrıca doğrulanması önerilir.

5. Sonuç

db-prod-01 sunucusunda SSH, servis ve zaman / loglama kontrollerinin büyük ölçüde iyi yapılandırıldığı görülmektedir. Buna karşın kullanıcı envanteri ve yama yönetimi alanlarındaki bulgular, sorunun tekil eksiklerden değil süreçlerin işletilmemesinden kaynaklandığını göstermektedir. Önceliklendirme olarak önce ops hesabının sahipliği netleştirilip sudo yetkileri daraltılmalı ve bekleyen OpenSSH / OpenSSL güncellemeleri uygulanmalı, ardından kullanıcı yaşam döngüsü ve yama yönetimi süreçleri yazılı hale getirilerek tüm Unix sunucularına yaygınlaştırılmalıdır.